

CRA 24-Hour Reporting Kit

EU Cyber Resilience Act · Regulation (EU) 2024/2847 · Article 14

Toledo Technologies LLC

Version 1.0 — September 2026

- [CRA 24-Hour Reporting Kit — START HERE](#)
 - [What this pack is for](#)
 - [Scope note: which obligations are live today](#)
 - [What is in the pack](#)
 - [Where reports go](#)
 - [How to use this pack in the first hour](#)
 - [Ten-line quick-start](#)
 - [Companion tooling](#)
 - [Maintenance](#)
- [Decision Tree — Does this trigger an Article 14 report?](#)
 - [How to use this file](#)
 - [The six gates in one line each](#)
 - [ASCII decision tree](#)
 - [Numbered checklist](#)
 - [Three common wrong answers](#)
- [Timeline and Clocks](#)
 - [The three-stage cascade](#)
 - [Interim reports](#)
 - [Worked example — actively exploited vulnerability](#)
 - [Worked example — severe incident, same arithmetic style](#)
 - [When the 24-hour mark arrives and you still know almost nothing](#)
 - [Weekend, holiday and handover arithmetic](#)
 - [Deadline computation worksheet](#)
 - [Platform counters are not your deadline](#)
- [Report Templates](#)
 - [How to use these templates](#)
 - [Template 1 — EARLY WARNING \(within 24 hours of becoming aware\)](#)
 - [Template 2 — 72-HOUR NOTIFICATION \(within 72 hours of becoming aware\)](#)
 - [Template 3 — FINAL REPORT](#)
 - [Pre-submission checklist](#)
- [Evidence and Decision Log](#)
 - [Why this log is the most important file in the pack](#)
 - [Rules for keeping it](#)
 - [Entry types](#)
 - [Log table template](#)
 - [Filled example — Event EVT-2026-0141, actively exploited vulnerability](#)
 - [Filled example — a decision NOT to report](#)
 - [Common failures this log prevents](#)
- [Roles and Dry Run](#)

- [The staffing principle](#)
- [Roles in the first 24 hours](#)
- [The first 24 hours, by the clock](#)
- [30-minute tabletop dry run](#)
- [One-page wall chart](#)
- [Pre-incident readiness checklist](#)

CRA 24-Hour Reporting Kit — START HERE

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

What this pack is for

Since **11 September 2026**, Article 14 of Regulation (EU) 2024/2847 (the Cyber Resilience Act, “CRA”) requires manufacturers of products with digital elements to notify two categories of event to a coordinating national CSIRT and to ENISA:

1. any **actively exploited vulnerability** contained in the product, and
2. any **severe incident** having an impact on the security of the product.

The first notification — the early warning — is due **within 24 hours of becoming aware**. That deadline runs through nights, weekends and public holidays. Most organisations that miss it do not miss it because they lacked the technical skill to assess the event. They miss it because nobody knew who was allowed to press “submit”, or because the 24-hour clock had already been running for eleven hours by the time anyone realised it had started.

This pack exists to remove both failure modes. It is the process layer around the legal obligation: who decides, on what evidence, by when, and what artefact you retain afterwards.

Scope note: which obligations are live today

Obligation	Applies from	Legal basis
Article 14 reporting (actively exploited vulnerabilities, severe incidents)	11 September 2026	Article 71(2), second sentence
Notification of conformity assessment bodies (Chapter IV)	11 June 2026	Article 71(2), second sentence
Main CRA obligations (essential requirements, CE marking, vulnerability handling, CVD policy, SBOM, support periods)	11 December 2027	Article 71(2)
Reporting obligations for open-source software stewards (Article 24(3))	11 December 2027	Article 71(2)

Two consequences people routinely get wrong:

- **Products already on the EU market are in scope now.** Article 69(3) disapplies the usual transitional carve-out for Article 14. Reporting applies to all in-scope products with digital elements placed on the market before

11 December 2027. A product you shipped in 2019 and no longer actively develop still generates a reporting duty if you become aware that a vulnerability in it is being actively exploited.

- **Reporting outlives the support period.** The Commission’s guidance of 27 July 2026 (Section 9.1) states that, unlike vulnerability handling obligations, the reporting obligations continue to apply after a product is no longer supported. You may be required to notify a vulnerability you are not required to fix.

Non-compliance with Article 14 sits in the CRA’s highest penalty tier: administrative fines of up to **EUR 15 000 000 or 2.5 % of total worldwide annual turnover for the preceding financial year, whichever is higher** (Article 64(2)). One narrow relief exists: under Article 64(10)(a), the administrative fines do not apply to manufacturers qualifying as microenterprises or small enterprises specifically for a failure to meet the 24-hour early-warning deadline. That relief covers the deadline only — not the obligation to report, and not the 72-hour or final-report stages.

What is in the pack

File	What it answers	When you open it
00-START-HERE.md	Orientation, quick-start, how the pack fits together	Now, before an incident
01-DECISION-TREE.md	“Does this trigger an Article 14 report?”	First 60 minutes, every time
02-TIMELINE-AND-CLOCKS.md	When each deadline falls and how to compute it	As soon as awareness is declared
03-REPORT-TEMPLATES.md	Fill-in-the-blank text for all three stages	Before you open the reporting platform
04-EVIDENCE-LOG.md	The record that proves when you knew and why you decided	Continuously, from the first signal
05-ROLES-AND-DRY-RUN.md	Who does what; a 30-minute tabletop script	Before an incident, and at handover

The pack is deliberately paper-first. Everything in it works on a phone, at 03:00, from a hotel, with no access to internal tooling.

Where reports go

Notifications under Article 14(1) and (3) are submitted through the **single reporting platform** established by ENISA under Article 16. You submit once. The submission goes to the **CSIRT designated as coordinator** that you select, and is simultaneously made available to **ENISA** (subject to the narrow exception in Article 16(2)). That CSIRT then disseminates to other Member States’ CSIRTs where you have indicated the product is available.

- Platform entry point: <https://portal.cra-srp.enisa.europa.eu> — [VERIFY: confirm the current entry point on ENISA's Single Reporting Platform page before relying on this URL]
- Access requires an **EU Login account with multi-factor authentication enabled**, held personally by each Assigned Representative who will submit.
- Your coordinating CSIRT is determined by Article 14(7): normally the Member State of your main establishment in the Union — the place where decisions about the cybersecurity of your products are predominantly taken. If you have no main establishment in the Union, the fallback order is authorised representative, then importer, then distributor, then user concentration.
- [VERIFY: your coordinating CSIRT and its contact details – see ENISA's published list of CSIRTs designated as coordinators, and your national CSIRT's own website]

Selecting the wrong coordinating CSIRT can cause a notification to be invalidated and require resubmission. Determine yours **before** you need it and record it in the wall-chart in `05-ROLES-AND-DRY-RUN.md`.

How to use this pack in the first hour

Assume a signal has just arrived: a customer report, a threat-intel advisory, a honeypot hit, an anomalous telemetry cluster, a message from a national agency.

Minutes 0–10 — Open the log, do not start the clock. Open `04-EVIDENCE-LOG.md` and record the signal: what arrived, from whom, at what UTC timestamp, and the raw text. Receiving an unverified tip is **not** awareness. Recording it is how you later prove the difference.

Minutes 10–40 — Run the decision tree. Work `01-DECISION-TREE.md` top to bottom with the technical verifier. The tree has six gates: product in scope; made available on the EU market; real-world exploitation evidence (not CVSS, not a public proof-of-concept); reachability in *your* product if the flaw came from a third-party component; the severe-incident test; and the awareness test. Write the answer and the reason for each gate into the log as you go.

Minute 40 — Declare or defer, explicitly. Either the initial assessment yields a **reasonable degree of certainty** that a vulnerability in your product is being actively exploited or that a severe incident has occurred and compromised your product’s security — in which case you declare awareness, stamp T0 in UTC, and the 24-hour clock starts — or it does not, in which case you record precisely what is still missing and set a named re-assessment time. Silence is the one outcome that is not available. The Commission’s guidance emphasises **prompt action** to carry out the initial assessment; you cannot defer awareness by declining to investigate.

Minutes 40–60 — Start the reporting track in parallel with the technical track. The accountable reporter takes `02-TIMELINE-AND-CLOCKS.md`, writes the three deadlines on the wall in UTC, and begins drafting the early warning from the template in `03-REPORT-TEMPLATES.md`. Meanwhile engineering continues the investigation. These two tracks must not be serialised — waiting for engineering to “finish” is how the 24 hours are lost.

Ten-line quick-start

1. Signal arrives. Log it verbatim with a UTC timestamp. Do not yet call it awareness.
2. Page the accountable reporter and the technical verifier. One name each, no committees.
3. Run `01-DECISION-TREE.md`. Record an answer and a reason at every gate.
4. Exploitation evidence means observed real-world abuse, not a high CVSS score and not a public PoC.
5. Third-party component? Ask whether the flaw is reachable and actually exploited **in your product**.
6. If yes at every gate: declare awareness. Stamp **T0 in UTC** in the evidence log. Say it out loud.
7. Compute and post the three deadlines: T0+24h, T0+72h, and the final-report date (`02-TIMELINE-AND-CLOCKS.md`).
8. File the early warning by T0+24h even if you still know very little. It is designed to be thin.
9. Inform impacted users as required by Article 14(8), proportionately — this is a separate duty from notifying the CSIRT.
10. If you decide **not** to report, write the reason, the evidence relied on, and the decision-maker’s name in `04-EVIDENCE-LOG.md`. That entry is your defence.

Companion tooling

The free, MIT-licensed CLI `cra-watch` scans a project’s dependencies and flags components carrying CVEs listed in the CISA Known Exploited Vulnerabilities (KEV) catalog. The KEV catalog is a free JSON feed at

https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json; as of 11 September 2026 it carried 1,709 entries.

Use it correctly. A KEV listing is strong practical evidence that a vulnerability is being exploited *somewhere in the world* — it is an excellent trigger for an initial assessment, and it is the input this pack expects. It is **not** a legal determination that the vulnerability is being exploited **in your product**, and CISA’s catalog is a US federal instrument with no status under the CRA. The step from “KEV-listed component in my SBOM” to “actively exploited vulnerability contained in my product with digital elements” is exactly the reachability question at gate 4 of the decision tree, and it is yours to answer and document.

Maintenance

Review this pack whenever any of the following changes: your main establishment in the Union; your authorised representative, importers or distributors; the identity of the accountable reporter or deputy; the product inventory made available on the EU market; or the published guidance from the Commission, ENISA or your coordinating CSIRT. Run the tabletop in 05-ROLES-AND-DRY-RUN.md at least twice a year and after every change of accountable reporter.

Decision Tree — Does this trigger an Article 14 report?

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

How to use this file

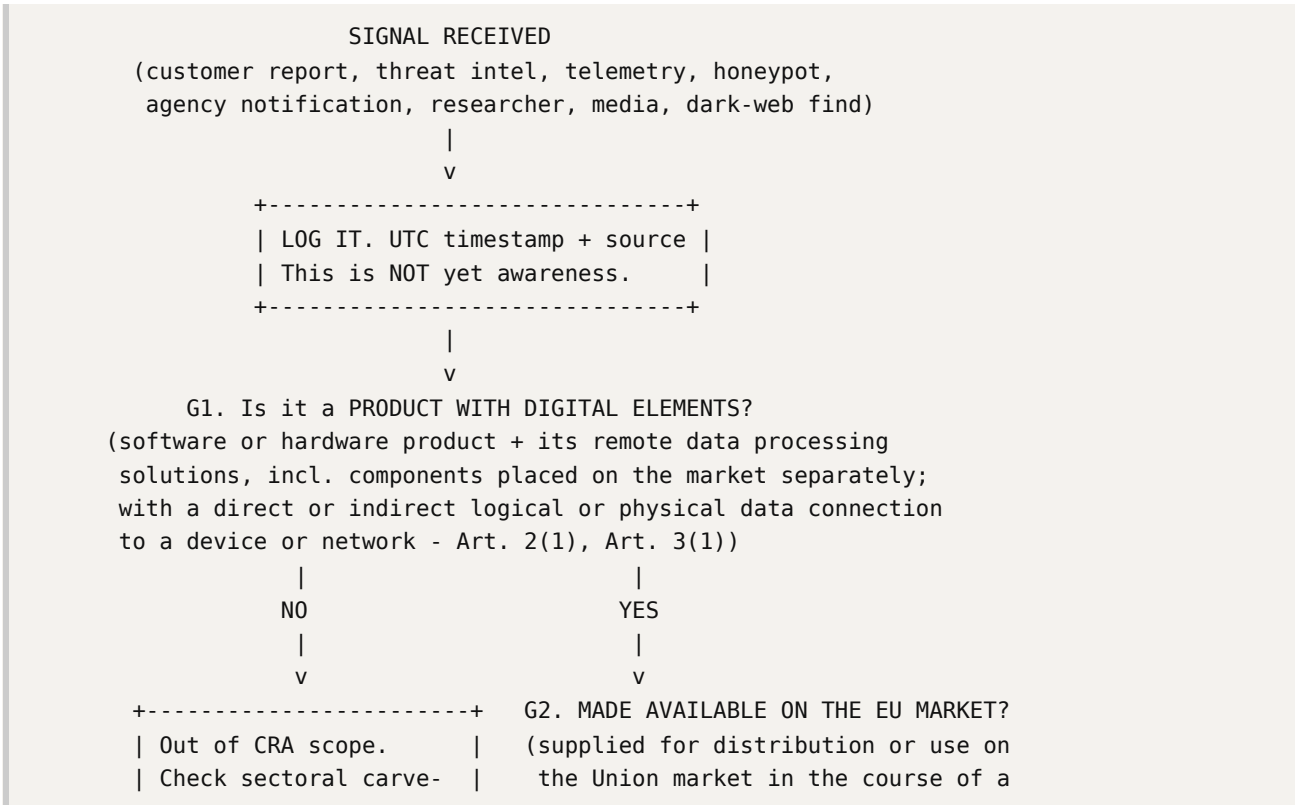
Run every gate in order. At each gate write the answer **and the reason** into 04-EVIDENCE-LOG.md before moving on. The tree is not a formality — the written reasons are what defend either decision later, including the decision not to report.

Two people run it: the **technical verifier** answers the factual questions; the **accountable reporter** owns the conclusion and the timestamp. Do not run it alone, and do not run it in a group larger than three.

The six gates in one line each

1. **Product** — is it a product with digital elements within CRA scope?
2. **Market** — is it made available on the EU market, by any route?
3. **Exploitation** — is there reliable evidence of real-world exploitation by a malicious actor?
4. **Reachability** — if the flaw came from a third-party component, is it exploitable and exploited *in your product*?
5. **Incident** — alternatively, does this meet the Article 14(5) severe-incident test?
6. **Awareness** — has an initial assessment produced a reasonable degree of certainty? That is when T0 starts.

ASCII decision tree



<pre> outs actually apply (Art. 2(2)-(7)). Log and close. +-----+ </pre>	<pre> commercial activity, paid or free - Art. 3(22); ANY route counts: direct, importer, distributor, authorised representative, OEM, white-label, app store) NO YES v v </pre>
<pre> +-----+ Not an EU-market product -> no Art. 14 duty for this product. Other duties may still apply. Log and close. +-----+ </pre>	<pre> +-----+ Continue. Note: products placed on the market BEFORE 11 Dec 2027 are IN SCOPE for Art. 14 (69(3)). +-----+ </pre>
<pre> +-----+ v </pre>	<pre> +-----+ v </pre>
TRACK A: VULNERABILITY <pre> v </pre>	TRACK B: INCIDENT <pre> v </pre>
G3. ACTIVELY EXPLOITED? Reliable evidence that a MALICIOUS ACTOR has exploited it in a system WITHOUT the system owner's permission (Art. 3(42)). YES-ish evidence: - exploitation observed in your telemetry / logs - customer confirms breach traced to this flaw - credible IR/threat-intel report of in-the-wild use - national agency states it is being exploited - exploit sold/traded with evidence of real use NOT sufficient on its own: - high CVSS / EPSS score - "critical" severity label - public proof-of-concept - exploit code on GitHub - bug-bounty or pentest find - researcher disclosure with no malicious use - vendor advisory that says "could be exploited" <pre> +-----+ NO YES </pre>	G5. SEVERE INCIDENT? Does the incident affect the SECURITY of the product, and: (a) negatively affect, or be capable of negatively affecting, the product's ability to protect the availability, authenticity, integrity or confidentiality of SENSITIVE or IMPORTANT data or functions; OR (b) has led, or is capable of leading, to the introduction or execution of MALICIOUS CODE in the product or in a user's network and information systems? (Art. 14(5)) <pre> NO YES v +-----+ Not a severe incident. Handle internally. Log reason. Art. 15 voluntary notification stays open. +-----+ </pre>

V	V	
+-----+	G4. THIRD-PARTY COMPONENT ORIGIN?	
Not an actively	Did the flaw arrive in a component	
exploited vuln.	you integrated rather than code you wrote?	
NO mandatory		
Art. 14 report.	NO	YES
Still required:		
- vuln		V
handling		Is the vulnerable code
(from Dec		REACHABLE and ACTUALLY
2027)		EXPLOITED in YOUR
- upstream		product?
report,		
Art. 13(6)	NO	YES
Art. 15		
voluntary	V	
notification	+-----+	
stays open.	NOT an AEV	
LOG THE REASON.	"contained in	
+-----+	your product".	
	No mandatory	
	report for you.	
	Component	
	maker may still	
	owe one.	
	Report upstream	
	(Art. 13(6)).	
	LOG THE REASON.	
	+-----+	
	+-----+	
	V	V
	G6. AWARENESS TEST – has an initial assessment	
	given you a REASONABLE DEGREE OF CERTAINTY that	
	(i) a vulnerability in your product is being	
	actively exploited, or (ii) a severe incident	
	has occurred and has compromised the security	
	of your product?	
	+-----+	
	NO	YES
	V	V
+-----+	+-----+	
NOT YET AWARE.	AWARENESS DECLARED.	
Keep investigating	STAMP T0 IN UTC. SAY IT ALOUD.	
PROMPTLY. Set a named	Deadlines now run:	
re-assessment time.	EARLY WARNING T0 + 24h	
Record exactly what is	NOTIFICATION T0 + 72h	
missing and who is	FINAL REPORT see file 02	
getting it. You CANNOT	Also: inform impacted users	
defer awareness by	(Art. 14(8)), proportionately.	
declining to investigate.	Go to 03-REPORT-TEMPLATES.md.	
+-----+	+-----+	

Numbered checklist

Complete every line. “Unknown” is a permitted answer only with a named owner and a time by which it will be resolved.

Gate 1 — Product with digital elements

- ☐ **1.1** Identify the exact product, including version, release, build, model or firmware revision.
- ☐ **1.2** Confirm it is a software or hardware product, or its remote data processing solution, or a component placed on the market separately (Article 3(1)).
- ☐ **1.3** Confirm its intended purpose or reasonably foreseeable use includes a direct or indirect logical or physical data connection to a device or network (Article 2(1)). Fully air-gapped products with no such connection fall outside.
- ☐ **1.4** Confirm none of the exclusions in Article 2(2) to (7) applies — notably medical devices under Regulation (EU) 2017/745 and (EU) 2017/746, motor vehicles under Regulation (EU) 2019/2144, civil aviation products certified under Regulation (EU) 2018/1139, marine equipment under Directive 2014/90/EU, identical spare parts, and products developed exclusively for national security or defence. Confirm the exclusion actually applies to *this* product rather than to your sector generally.
- ☐ **1.5** Confirm you are the **manufacturer** for this product: you develop or manufacture it, or have it designed, developed or manufactured, and market it under your own name or trademark (Article 3(13)). White-labelling someone else’s product under your brand makes you a manufacturer.

Gate 2 — Made available on the EU market

- ☐ **2.1** Is the product supplied for distribution or use on the Union market in the course of a commercial activity — whether for payment or free of charge (Article 3(22))? Free-of-charge distribution counts.
- ☐ **2.2** Check **every** route, not just direct sales: your own sales; an importer established in the Union; a distributor; an authorised representative acting under written mandate; an OEM or white-label partner; a cloud or app-store distribution channel; bundling inside another manufacturer’s product.
- ☐ **2.3** List the Member States where, to your knowledge, the product has been made available. You will be asked for this in the early warning.
- ☐ **2.4** Do not exclude the product because it was placed on the market before the CRA applied. **Article 69(3)** makes Article 14 apply to all in-scope products placed on the market before 11 December 2027.
- ☐ **2.5** Do not exclude the product because its support period has ended. Per the Commission guidance of 27 July 2026, Section 9.1, reporting continues to apply after a product is no longer supported.

Gate 3 — Actively exploited (Track A)

The CRA definition, Article 3(42): *a vulnerability for which there is reliable evidence that a malicious actor has exploited it in a system without permission of the system owner.*

- ☐ **3.1** State the specific evidence of real-world exploitation, with source and UTC timestamp.
- ☐ **3.2** Confirm the evidence shows a **malicious actor** acting **without the system owner’s permission**. Recital 68 excludes vulnerabilities discovered with no malicious intent for good-faith testing, investigation, correction or disclosure.
- ☐ **3.3** Explicitly confirm you are **not** relying on any of the following alone: a high CVSS or EPSS score; a “critical” label; a public proof-of-concept; exploit code published on a repository; an advisory saying the flaw “could be” or “is likely to be” exploited; a bug-bounty submission; a penetration-test finding; a coordinated-disclosure report with no evidence of malicious use.

- ☐ **3.4** A KEV listing (CISA Known Exploited Vulnerabilities catalog) or an equivalent government exploitation advisory is strong practical evidence that exploitation is occurring somewhere. Treat it as a trigger to assess, and record it as evidence — but it does not by itself establish exploitation **in your product**. Go to Gate 4.
- ☐ **3.5** Zero-day status is irrelevant to the trigger. A vulnerability with no patch available is reportable when there is reliable evidence of malicious exploitation, and not reportable merely because it is unpatched.
- ☐ **3.6** If the evidence is a rumour, an unattributed social-media post, a vague customer suspicion, or a third-hand claim: this is **not** yet reliable evidence. Record it, assess it promptly, and move to Gate 6 with “not yet aware” — do not close the file.

Gate 4 — Third-party component reachability (Track A)

Per the Commission guidance of 27 July 2026, Section 9.1, paragraph 218:

- ☐ **4.1** Where your product contains an actively exploited vulnerability **originating from a third-party component**, you as the manufacturer of the finished product are required to notify it. The manufacturer of the component is also required to notify it, if that component was itself placed on the market. Both duties can exist simultaneously; theirs does not discharge yours.
- ☐ **4.2** However, if the vulnerability **cannot be exploited in your product** — for example because the vulnerable code is not reachable in your build, the affected feature is not compiled in, the vulnerable code path is unreachable given your configuration, or a compensating control makes exploitation impossible — then it is not an actively exploited vulnerability *contained in your product* and there is no mandatory report for you.
- ☐ **4.3** Equally, if the vulnerability is reachable in principle but **has not been exploited in your product**, it does not qualify as an actively exploited vulnerability contained in your product, and there is no mandatory report for you.
- ☐ **4.4** Write down the reachability analysis: which version of the component you ship, which code path is affected, whether that path is callable in your product, what configuration or control blocks it, and who verified it. This is the single most contestable judgement in the whole tree and the most likely to be examined later.
- ☐ **4.5** If you conclude “not reportable” at this gate, two obligations remain live: report the vulnerability upstream to the person or entity manufacturing or maintaining the component (Article 13(6)), and handle the vulnerability under Part II of Annex I once those obligations apply. Voluntary notification under Article 15 also remains available.
- ☐ **4.6** Re-run this gate whenever new evidence arrives. A “not reachable” conclusion is valid as of the facts known at the time; it is not permanent.

Gate 5 — Severe incident (Track B)

The Article 14(5) test. An incident having an impact on the security of the product is **severe** where **either**:

- ☐ **5.1** (a) it negatively affects, or is capable of negatively affecting, the ability of the product to protect the **availability, authenticity, integrity or confidentiality of sensitive or important data or functions; or**
- ☐ **5.2** (b) it has led, or is capable of leading, to the **introduction or execution of malicious code** in the product, or in the network and information systems of a user of the product.
- ☐ **5.3** Note the orientation of Track B. Recital 68 describes severe incidents as situations where a cybersecurity incident affects the manufacturer’s **development, production or maintenance processes** in a way that could result in increased cybersecurity risk for users — the canonical example being an attacker successfully introducing malicious code into the release channel through which you ship security updates.
- ☐ **5.4** “Capable of” is a forward-looking test. You do not need to wait for harm to materialise. A compromised build server with signing access satisfies (b) before a single malicious artefact reaches a user.

- ☐ **5.5** A general corporate IT breach is not automatically a severe incident under Article 14. Ask specifically whether it affects the security of a **product with digital elements** you make available. A compromise of your CRM is not in Track B; a compromise of your code-signing key is.
- ☐ **5.6** Record whether the incident is **suspected of being caused by unlawful or malicious acts** — the early warning asks for this.
- ☐ **5.7** The same event can be both an actively exploited vulnerability and a severe incident. If so, assess both tracks; they carry different final-report deadlines (see `02-TIMELINE-AND-CLOCKS.md`).

Gate 6 — Awareness: when the clock starts

The Commission’s guidance of 27 July 2026, Section 9.1, paragraphs 211 to 214, is the operative standard, and it is aligned with recital 31 of Commission Implementing Regulation (EU) 2024/2690 and Section II(A) of the EDPB Guidelines 9/2022 on personal data breach notification.

- ☐ **6.1** Where you detect a suspicious event, or a third party — an individual, customer, entity, authority, media organisation or other source — brings a potential incident or vulnerability to your attention, you must **assess the suspicious event immediately**.
- ☐ **6.2** You are regarded as having become aware when, **after that initial assessment**, you have a **reasonable degree of certainty** that (i) a vulnerability contained in your product is being actively exploited, or (ii) a severe incident has occurred and has led to the security of your product being compromised.
- ☐ **6.3** Therefore: a rumour, an unverified tip, an unconfirmed report, or a media claim you have not yet assessed does **not** start the clock. The receipt of that signal starts your **duty to assess promptly**, not the 24-hour deadline.
- ☐ **6.4** Equally: you cannot suppress the clock by not investigating. The guidance places the emphasis on **prompt action** to carry out the initial assessment, particularly where the vulnerability may pose a significant risk. Slow-walking the assessment is not a defence; it is an aggravating fact.
- ☐ **6.5** Certainty is “reasonable”, not absolute. You do not need root cause, a patch, an actor attribution, a full scope, or a complete list of affected customers. If you are waiting for any of those before declaring awareness, you have set the bar too high.
- ☐ **6.6** Stamp **T0** as a specific UTC date and time in `04-EVIDENCE-LOG.md`, name the person who declared it, and state the fact that tipped the assessment over into reasonable certainty.
- ☐ **6.7** Vulnerabilities whose **active exploitation you already knew about before 11 September 2026** are not retroactively reportable. But if you knew of the vulnerability before that date and only became aware of its active exploitation after it, the duty applies.
- ☐ **6.8** If the answer is “not yet aware”: record what specific fact is missing, who owns getting it, and the UTC time of the next re-assessment. Put that re-assessment in a calendar with an alarm.

Three common wrong answers

“The CVSS is 9.8, so we must report.” No. Severity is not exploitation. Article 3(42) requires reliable evidence that a malicious actor has exploited the flaw in a system without the owner’s permission. A 9.8 with no evidence of real-world abuse is not reportable under Article 14 — though it is very likely worth a voluntary notification under Article 15 and certainly worth a patch.

“There’s a working PoC on GitHub, so it’s actively exploited.” No. A public proof-of-concept demonstrates exploitability, not exploitation. It sharply raises the probability that exploitation will follow, which is a reason to raise monitoring and accelerate the fix, and a reason to re-assess frequently — but on its own it is not the reliable evidence the definition requires.

“The CVE is in our SBOM and it’s in KEV, so we have 24 hours.” Not yet. KEV tells you the flaw is being exploited somewhere. Gate 4 asks whether it is reachable and exploited **in your product**. Answer that question, in writing, before the clock is declared — and answer it fast, because if the answer is yes, the clock started when your assessment reached reasonable certainty, not when you finished writing it up.

Timeline and Clocks

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

The three-stage cascade

Article 14 does not ask for one report. It asks for a cascade of three, each proportionate to what you can reasonably know at that point. The design intent is that you report early and thinly, then thicken the record as the investigation advances. The Commission’s guidance of 27 July 2026, Section 9.1, paragraph 215, states this directly: manufacturers are required to **update their notifications progressively** as their internal investigations advance.

Stage	Actively exploited vulnerability (Art. 14(1),(2))	Severe incident (Art. 14(3),(4))
1. Early warning	Without undue delay, and in any event within 24 hours of becoming aware . Indicate, where applicable, the Member States where you are aware the product has been made available.	Same 24-hour deadline. Must include at least whether the incident is suspected of being caused by unlawful or malicious acts , and, where applicable, the Member States concerned.
2. Fuller notification	Vulnerability notification within 72 hours of becoming aware . General information, as available, about the product; the general nature of the exploit and of the vulnerability; corrective or mitigating measures taken and measures users can take; and an indication of how sensitive you consider the information to be.	Incident notification within 72 hours of becoming aware . General information about the nature of the incident; an initial assessment; corrective or mitigating measures taken and measures users can take; sensitivity indication.
3. Final report	No later than 14 days after a corrective or mitigating measure is available . Must include at least: a description of the vulnerability including severity and impact; where available, information on any malicious actor that has exploited or is exploiting it; and details of the security update or other corrective measures made available.	Within one month after the submission of the 72-hour incident notification . Must include at least: a detailed description of the incident including severity and impact; the type of threat or root cause likely to have triggered it; and applied and ongoing mitigation measures.

Three structural points that catch people out:

The two final-report clocks are anchored differently. For a vulnerability, the 14 days run from the moment a corrective or mitigating measure becomes **available** — not from awareness, and not from the 72-hour notification. That deadline therefore does not exist until you have a fix or a mitigation. For a severe incident, the one month runs from **submission of the 72-hour notification** — a date entirely within your control and knowable the moment you file stage 2.

A mitigating measure counts, not only a patch. If you publish a workaround, a configuration change, a firewall rule or a feature toggle that mitigates the risk, the 14-day clock starts then. Shipping a documented workaround on

day 2 and the permanent patch on day 40 means the final report was due on day 16, not day 54. Record the exact UTC time the mitigation became available to users.

Everything is “without undue delay” first, and the fixed period second. The 24- and 72-hour figures are backstops, not targets. If you have the information at hour 6, file at hour 6.

Interim reports

Under Article 14(6), where necessary the coordinating CSIRT that initially received your notification may **request an intermediate report** on relevant status updates. Treat such a request as a hard deadline with the same seriousness as the statutory ones, and log it.

Worked example — actively exploited vulnerability

All times UTC. Use UTC in every internal record; local time and daylight-saving changes are a proven source of one-hour errors that turn a compliant filing into a late one.

Facts. A mid-sized manufacturer ships an edge gateway appliance, firmware 4.0 through 4.2.1, made available in Belgium, Greece and Italy. Main establishment in the Union: Belgium. Coordinating CSIRT: [VERIFY: your coordinating CSIRT – see ENISA's published list of CSIRTs designated as coordinators].

UTC timestamp	Event	Clock status
Thu 2026-10-15 14:20	A customer’s SOC emails the product security inbox: “we think your appliance was the entry point, seeing odd outbound traffic from the management interface.” No detail attached.	Not awareness. Signal logged. Duty to assess promptly begins.
Thu 2026-10-15 14:35	Technical verifier paged. Customer asked for logs; internal telemetry review opened.	Assessment under way. Logged.
Thu 2026-10-15 17:10	Customer supplies management-interface logs showing authentication being bypassed on an unpatched 4.2.1 unit, followed by privileged API calls from an external address.	Strong, not yet confirmed against own build.
Thu 2026-10-15 18:40	Verifier reproduces the bypass against a stock 4.2.1 build and confirms the log pattern is exploitation, not misconfiguration. Accountable reporter declares awareness.	T0 = 2026-10-15 18:40 UTC. All clocks start.
Thu 2026-10-15 19:05	Deadlines posted: EW due Fri 2026-10-16 18:40; 72h due Sun 2026-10-18 18:40. Final report date unknown — depends on mitigation availability.	Posted on the wall and in the channel.
Fri 2026-10-16 09:50	Early warning submitted. ~9 hours early, ~15h10m after T0. Member States indicated: Belgium, Greece, Italy.	Stage 1 complete.
Fri 2026-10-16 16:30	Workaround published to customers: restrict management-interface access to trusted networks.	This is a mitigating measure , but it is not yet “available” as a corrective measure in the product; record the time and flag the ambiguity — see the note below.

UTC timestamp	Event	Clock status
Sun 2026-10-18 11:00	72-hour notification submitted , 7h40m before the deadline. Includes affected versions, general nature of the exploit, the published workaround, and sensitivity assessment.	Stage 2 complete.
Thu 2026-10-22 09:15	Firmware 4.2.2 released and downloadable by all customers. Corrective measure available.	14-day clock starts here.
Thu 2026-11-05 09:15	Final report due.	Filed Tue 2026-11-03 — two days early.

Arithmetic, shown explicitly.

- $T_0 = 2026-10-15\ 18:40\ \text{UTC}$ (Thursday).
- Early warning deadline = $T_0 + 24\text{h} = \mathbf{2026-10-16\ 18:40\ \text{UTC (Friday)}}$.
- Notification deadline = $T_0 + 72\text{h} = \mathbf{2026-10-18\ 18:40\ \text{UTC (Sunday)}}$. Note that this falls on a Sunday. Article 14 contains no working-day adjustment; the deadline is Sunday evening and you must staff for it.
- Corrective measure available = 2026-10-22 09:15 UTC (Thursday).
- Final report deadline = available + 14 days = **2026-11-05 09:15 UTC (Thursday)**.

The mitigation-timing ambiguity, handled properly. The Friday workaround is arguably a “mitigating measure available”, which would have started the 14-day clock on 2026-10-16 16:30 and made the final report due 2026-10-30 16:30. The manufacturer above resolved this the safe way: it recorded both candidate dates in the evidence log, adopted the **earlier** one as its working deadline, and filed well inside it. Where the trigger date is genuinely arguable, take the earliest defensible date. Filing early is free; filing late is in the EUR 15 000 000 / 2.5 % tier.

Worked example — severe incident, same arithmetic style

Facts. An attacker gains write access to the update distribution bucket used to ship signed firmware. No malicious artefact is confirmed to have reached a user, but the capability existed for an unknown period.

UTC timestamp	Event	Clock status
Sat 2026-11-07 02:15	Automated integrity check flags an unexpected object write in the update bucket.	Signal logged. Not awareness.
Sat 2026-11-07 04:50	Investigation confirms an unauthorised credential was used to write to the bucket. Gate 5(b) is met: the incident is capable of leading to the introduction of malicious code in the product. Awareness declared.	$T_0 = 2026-11-07\ 04:50\ \text{UTC}$.
Sat 2026-11-07 13:20	Early warning submitted. Field “incident suspected of being caused by unlawful or malicious acts” = Yes.	Due Sun 2026-11-08 04:50.
Mon 2026-11-09 15:00	72-hour incident notification submitted. Due Tue 2026-11-10 04:50.	Stage 2 complete. The one-month clock starts from this submission.
Wed 2026-12-09 15:00	Final report due — one month after the 72-hour notification was submitted, not one month after T_0 .	

Note the practical consequence: because the severe-incident final-report clock runs from your own submission of stage 2, filing stage 2 earlier pulls the final report earlier too. That is not a reason to delay stage 2 — the 72-hour deadline is absolute — but it is a reason to know the date the moment you press submit, and to write it on the wall.

When the 24-hour mark arrives and you still know almost nothing

You file anyway. This is the single most important operational rule in the pack.

The early warning is deliberately thin. Article 14(2)(a) asks, for a vulnerability, for notification of the actively exploited vulnerability and, where applicable, an indication of the Member States where you are aware the product has been made available. Article 14(4)(a) asks, for a severe incident, for at least whether the incident is suspected of being caused by unlawful or malicious acts, plus the same Member State indication. The Commission's guidance describes the early warning as **containing limited information**. It exists to trigger coordination, not to demonstrate that you have solved the problem.

What to do at T0+20h when the picture is still fragmentary:

1. **File with what you have.** Incomplete is compliant. Absent is not.
2. **Say plainly what is unknown.** “Root cause not yet established.” “Affected version range under confirmation; 4.2.1 confirmed affected.” “Scope of impacted customers under assessment.” Unknowns stated as unknowns are accurate reporting.
3. **Never speculate to fill a field.** Do not guess at an actor, a scope, a customer count, or a root cause. An early warning that later proves wrong because you guessed is worse than one that said “under investigation”.
4. **Do not withhold the early warning to co-ordinate a PR statement.** The notification to the CSIRT and ENISA is not a public disclosure. Article 16 provides for confidentiality, and Article 16(2) provides for delayed dissemination on justified cybersecurity-related grounds, including where a coordinated vulnerability disclosure process is ongoing. Use the mechanism the regulation gives you rather than missing the deadline.
5. **Use the sensitivity field.** At the 72-hour stage you may indicate how sensitive you consider the notified information to be. Where you are reporting an unpatched exploitation path, say so and explain why restricted handling is warranted rather than attaching a generic confidentiality boilerplate.
6. **Keep the record moving.** Every field left blank at stage 1 becomes an action item with an owner and a target time for stage 2.
7. **Re-check the Member State list.** This is the one field people leave empty because it feels like sales data. Your distributor and importer records answer it; pull them before the incident, not during it.

Weekend, holiday and handover arithmetic

The clock does not pause. A T0 on Friday at 17:00 UTC puts the early warning at Saturday 17:00 UTC and the 72-hour notification at Monday 17:00 UTC. A T0 on 23 December puts the notification inside the holiday shutdown.

Concrete mitigations, all of which are pre-incident work:

- Name a **deputy reporter** with equal authority to file, and make sure their platform access is provisioned and tested, not theoretical.
- Ensure at least two people hold a working **EU Login account with MFA enabled** and are registered on the reporting platform. One Primary Assigned Representative plus at least one Secondary is the minimum resilient configuration. Test a login quarterly — a stale MFA enrolment discovered at hour 22 is a compliance failure with a trivial cause.
- Put **absolute UTC deadlines** in a shared calendar with alarms at T0+12h, T0+20h, T0+60h and T0+68h. Relative countdowns in a chat channel are not sufficient.

- Agree in advance that the reporter may file **without further sign-off**. Approval chains that require an executive who is on a flight are how 24-hour deadlines are missed.

Deadline computation worksheet

Copy this block into the incident record and fill it in the moment awareness is declared.

T0 (awareness, UTC)	:	__-__-__ __:__	
declared by	:	_____	
fact that established certainty	:	_____	
Early warning due (T0 + 24h)	:	__-__-__ __:__	filed: __-__-__ __:__
72h notification due (T0 + 72h)	:	__-__-__ __:__	filed: __-__-__ __:__
TRACK A - actively exploited vulnerability			
Mitigating measure available (UTC):	:	__-__-__ __:__	
Corrective measure available (UTC):	:	__-__-__ __:__	
Earliest defensible trigger date	:	__-__-__ __:__	
Final report due (trigger + 14d)	:	__-__-__ __:__	filed: __-__-__ __:__
TRACK B - severe incident			
72h notification SUBMITTED at	:	__-__-__ __:__	
Final report due (+ 1 month)	:	__-__-__ __:__	filed: __-__-__ __:__
Interim report requested by CSIRT?	:	Yes / No	due: __-__-__ __:__
Users informed under Art. 14(8)?	:	Yes / No	at: __-__-__ __:__ how: _____

Platform counters are not your deadline

The reporting platform displays its own counters and sends reminder emails. They are convenience features and, at the initial release, they do not all match the statutory clock — the 72-hour counter has been documented as computing from submission of the early warning rather than from the moment of awareness, which can display a notification as overdue before 72 hours have actually elapsed. Likewise, no counter can know when your corrective measure became available.

Compute your own deadlines from T0 and from the mitigation-availability timestamp, keep them in your own calendar, and treat any platform counter as a secondary reminder only. [VERIFY: current counter behaviour in the platform's published guidance before relying on any on-screen due date]

Report Templates

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

How to use these templates

These are **drafting templates**, not a replica of any submission form. You draft here — offline, in a document you control — and then transcribe into the reporting platform. Three reasons this order matters:

1. The platform is a web form. Drafting in it risks losing work, and it gives you no version history of what you said and when.
2. You need your own copy of every word submitted. The platform is not your evidence archive; 04-EVIDENCE-LOG.md is.
3. Drafting offline forces the reporter to write complete sentences rather than fragments, which is what makes the record defensible six months later.

The field names below follow the structure of Article 14 and the categories the platform’s published guidance describes. Exact on-screen labels, character limits and which fields are mandatory at each stage can change between platform releases. [VERIFY: the current field list, character limits and mandatory/optional status against the platform's published glossary and user guidance before submitting]

Writing standard for every field. Factual, neutral, dated, attributed. Write what you observed and what you concluded, and mark the difference between them. No hedging adverbs, no marketing language, no blame, no speculation about actors you have not evidenced, no promises about future timelines you do not control. If a fact is estimated, say it is estimated. If something is unknown, write “not established as at ” rather than leaving a blank.

Template 1 — EARLY WARNING (within 24 hours of becoming aware)

```

=== CRA ARTICLE 14 EARLY WARNING - DRAFT ===
Internal reference      : _____
Drafted by             : _____
Reviewed by            : _____
Draft completed (UTC)   : ____-__-__ __:__
Submitted (UTC)         : ____-__-__ __:__
Platform submission ref : _____

--- ROUTING ---
Notification type       : [ ] Actively exploited vulnerability
                        : [ ] Severe incident
Manufacturer (legal name) : _____
CSIRT designated as
  coordinator selected   : _____
Basis for that selection : [ ] main establishment in the Union
                        : [ ] authorised representative
                        : [ ] importer [ ] distributor [ ] users

Member States where the
  product has been made
  available (as known)   : _____

```

```

--- SUBJECT ---
Title (short, specific)      : _____
Summary (factual overview:
  what is affected, what is
  happening, current
  mitigation status)        : _____
                             _____
Product name                 : _____
Product version / build /
  model / firmware range    : _____
Affected component (if
  attributable)             : _____
CVE ID (if assigned)        : _____
EUVD ID (if assigned)       : _____

--- TIMING ---
Date/time became aware
  (T0, UTC)                 : ____-__-__ __:__  [ ] exact [ ] estimated
Basis of the awareness
  determination             : _____

--- VULNERABILITY TRACK ONLY ---
Nature of exploitation
  observed (one or two
  factual sentences)        : _____

--- INCIDENT TRACK ONLY ---
Suspected to be caused by
  unlawful or malicious
  acts?                     : [ ] Yes  [ ] No  [ ] Unknown
Date/time incident occurred
  or began (UTC, if known) : ____-__-__ __:__  [ ] exact [ ] estimated

--- STATUS ---
Mitigating measure expected
  shortly?                  : [ ] Yes  [ ] No  [ ] Unknown
User action currently able
  to reduce impact          : _____
Known unknowns at this
  stage (state explicitly)  : _____
=== END ===

```

What good looks like — early warning

Title: Active exploitation of authentication bypass in GW-500 gateway firmware 4.2.1

Summary: On 2026-10-15 a customer reported anomalous outbound traffic from the management interface of a GW-500 appliance running firmware 4.2.1. Customer-supplied logs show authentication being bypassed on the management interface, followed by privileged API calls from an external address. Our security team reproduced the bypass against a stock 4.2.1 build on 2026-10-15 and assesses the customer logs as showing exploitation rather than misconfiguration. Affected version range is under confirmation; 4.2.1 is confirmed affected. No corrective measure is available yet. Interim user guidance is being prepared.

Product: GW-500 edge gateway. **Versions:** 4.2.1 confirmed affected; 4.0 to 4.2.0 under assessment.

Member States where made available: Belgium, Greece, Italy.

Became aware (UTC): 2026-10-15 18:40, exact. **Basis:** internal reproduction of the reported bypass against a stock build, combined with customer logs showing post-bypass privileged API activity from an external address.

Nature of exploitation observed: unauthenticated requests to a management-interface endpoint were accepted and executed with administrative privilege on a customer-operated unit.

Mitigating measure expected shortly: Yes.

Known unknowns: full affected version range; whether other customers are affected; root cause within the authentication path; actor identity.

Why this is good: every sentence is either an observation with a source or a stated conclusion with its basis. The affected range is honest about what is confirmed versus under assessment. The awareness basis is a specific event, not “we decided”. The unknowns are listed rather than hidden, and they map directly onto the work that will fill the 72-hour notification. It took about twenty minutes to write.

Contrast with a bad early warning: “We are investigating a potential security issue in one of our products and will provide more information when available.” That names no product, no version, no Member State, no awareness basis and no observed behaviour. It is functionally unactionable for a CSIRT, and it creates no record that helps you later.

Template 2 — 72-HOUR NOTIFICATION (within 72 hours of becoming aware)

This is the vulnerability notification under Article 14(2)(b) or the incident notification under Article 14(4)(b). Carry forward everything from the early warning, update anything that has changed, and add the substance below. Where information has already been provided and remains accurate, it does not need to be repeated — but do not leave a materially changed fact uncorrected.

=== CRA ARTICLE 14 - 72-HOUR NOTIFICATION - DRAFT ===

Internal reference : _____
 Links to early warning ref : _____
 Drafted / reviewed by : _____
 Submitted (UTC) : ____-__-__:__
 T0 (awareness, UTC) : ____-__-__:__
 Deadline (T0 + 72h, UTC) : ____-__-__:__

--- CARRIED FORWARD / UPDATED ---

Notification type : _____
 Product name : _____
 Product version range
 (updated) : _____
 Member States where made
 available (updated) : _____
 Component name and version : _____
 CVE ID / EUVD ID : _____
 Product regulatory type : ☐ default ☐ important ☐ critical
 Product class / category
 (if applicable) : _____
 End of support period
 reached? : ☐ Yes ☐ No

--- VULNERABILITY TRACK ---

General information about
the vulnerability and how
the known exploit operates: _____

Affected function / required
access / observed
exploitation behaviour : _____

Attack vector : _____

Assessed severity, with the
rationale for the rating : _____

--- INCIDENT TRACK ---

General information about
the nature of the incident: _____

Initial assessment (severity,
scope, affected security
properties, likely impact;
separate confirmed from
under investigation) : _____

Suspected unlawful or
malicious acts? : ☐ Yes ☐ No ☐ Unknown

--- MEASURES ---

Corrective or mitigating
measures TAKEN by us,
with dates (UTC) : _____

Corrective or mitigating
measures USERS can take : _____

Date/time any mitigating
measure became available
to users (UTC) : ____-__-__ __:__

Users informed under
Art. 14(8)? : ☐ Yes ☐ No ☐ In progress

- how, and to whom : _____

--- HANDLING ---

Sensitivity of the notified
information - what is
sensitive and what the
consequence of premature
or wider disclosure would
be (specific, not generic) : _____

Grounds for restricted or
delayed dissemination
considered? : ☐ Yes ☐ No

- if yes, which and why : _____

--- STILL OPEN ---

Outstanding investigation
items, with owners and
target dates : _____

=== END ===

What good looks like — 72-hour notification

General information about the vulnerability: A missing authentication check on the `/api/v1/admin` endpoint of the GW-500 management interface allows a remote actor with network access to the management interface to invoke privileged operations without credentials. The observed exploitation consists of a direct unauthenticated POST to that endpoint, followed by

creation of a persistent administrative account. Exploitation requires network reachability of the management interface; units with the management interface bound to a trusted network segment only are not reachable from the internet.

Affected versions: firmware 4.0 through 4.2.1 inclusive. Versions prior to 4.0 do not contain the affected endpoint.

Attack vector: remote, over the network, via the exposed HTTPS management interface. No authentication and no user interaction required.

Assessed severity: High. Rationale: unauthenticated remote access to administrative functions, confirmed exploitation in the wild on at least one customer-operated unit, no authentication or user interaction required. Mitigating factor: exploitation requires network reachability of the management interface, which our documented deployment guidance instructs users to restrict.

Corrective or mitigating measures taken: 2026-10-16 16:30 UTC — advisory published to all customers with instructions to restrict management-interface access to trusted networks. 2026-10-16 08:00 UTC — detection signature shared with our support organisation to identify the exploitation pattern in customer logs. Firmware 4.2.2 in test; release targeted for the week commencing 2026-10-19.

Measures users can take: Restrict access to the management interface to trusted network segments. Review management-interface logs for unauthenticated requests to `/api/v1/admin` since 2026-09-01. Review the administrative account list for accounts not created by your administrators. Install firmware 4.2.2 when available.

Users informed: Yes — advisory published on the customer portal and emailed to all registered GW-500 administrators on 2026-10-16 16:30 UTC.

Sensitivity: The endpoint path and request structure describe an exploitation path for which no security update is yet available. Wider publication before 4.2.2 ships would enable exploitation of units that have not yet applied the network restriction.

Why this is good: the severity rating carries its reasoning, so a reader can disagree with the rating without having to re-derive the facts. Measures taken carry UTC timestamps, which is what lets anyone reconstruct the 14-day final-report clock. User actions are ordered by effectiveness and are specific enough to execute. The sensitivity statement identifies the specific sensitive element and the specific consequence of disclosure, rather than asserting general confidentiality.

Template 3 — FINAL REPORT

Two different deadlines apply — see `02-TIMELINE-AND-CLOCKS.md`:

- **Actively exploited vulnerability:** no later than **14 days after a corrective or mitigating measure is available**.
- **Severe incident:** within **one month after submission of the 72-hour notification**.

=== CRA ARTICLE 14 FINAL REPORT - DRAFT ===

Internal reference	:	_____
Links to EW / 72h refs	:	_____
Drafted / reviewed by	:	_____
Submitted (UTC)	:	__-__-__:__

--- DEADLINE BASIS ---

Track : ☐ Vulnerability ☐ Severe incident

Vulnerability: date/time the
corrective or mitigating
measure became available : ____-__-__:__
-> due 14 days later : ____-__-__:__

Incident: date/time the 72h
notification was submitted: ____-__-__:__
-> due one month later : ____-__-__:__

--- VULNERABILITY TRACK (Art. 14(2)(c)) ---

(i) Full description of the
vulnerability, including
its SEVERITY : _____

(i) Full description of the
vulnerability, including
its IMPACT (systems,
components, data, users,
services affected) : _____

(ii) Information on any
malicious actor that has
exploited or is
exploiting it, where
available (observed
indicators; state
plainly if attribution
is unknown) : _____

(iii) Details of the security
update or other
corrective measures made
available to remedy it : _____
- version / build : _____
- release date (UTC) : ____-__-__:__
- distribution method : _____
- user action required : _____

--- INCIDENT TRACK (Art. 14(4)(c)) ---

(i) Detailed description of
the incident, including
its SEVERITY : _____

(i) Detailed description of
the incident, including
its IMPACT : _____

(ii) Type of threat or root
cause likely to have
triggered the incident : _____

(iii) Applied and ongoing
mitigation measures : _____

--- CLOSE-OUT ---

Uptake / remediation status
as known (e.g. proportion
of fleet updated) : _____

Users informed under
Art. 14(8) - final status : _____

Reported upstream to the
component maintainer
(Art. 13(6)), if

applicable : ☐ Yes ☐ No ☐ N/A date: ____-____-____

Changes made to prevent recurrence : _____

Residual risk and any remaining exposure : _____

=== END ===

What good looks like — final report

Full description including severity: The GW-500 management interface exposed `/api/v1/admin` without an authentication check, as a result of an authorisation middleware registration that was not applied to routes added in release 4.0. Any party able to reach the management interface over the network could invoke administrative operations, including creation of persistent administrative accounts. Assessed severity: High — unauthenticated remote administrative access, confirmed exploited in the wild, no user interaction required. Affected versions 4.0 through 4.2.1 inclusive.

Impact: Exploitation grants full administrative control of the affected appliance, including configuration change, traffic interception on interfaces terminating at the device, and persistence through account creation. Confirmed exploitation was observed on two customer-operated units. Log review across the supported fleet identified the exploitation pattern on no further units. No evidence was found of exploitation of our own infrastructure or of the firmware build or distribution systems.

Malicious actor: Attribution is unknown. Observed activity originated from two IP addresses in commercial hosting ranges; indicators were shared with affected customers and with [VERIFY: recipient – e.g. your coordinating CSIRT, where they have requested indicators] on 2026-10-20. The tooling observed is consistent with opportunistic mass scanning rather than targeted activity; this is an assessment, not a confirmed finding.

Corrective measures made available: Firmware 4.2.2, released 2026-10-22 09:15 UTC, applies the authorisation middleware to all management-interface routes and adds a startup check that fails closed if any route is registered without an authorisation policy. Distributed via the standard update channel and as a signed image on the customer portal. Users must apply the update; no automatic update is performed on this product line. The network-restriction workaround published on 2026-10-16 remains effective for units that cannot be updated immediately.

Remediation status as at 2026-11-03: 71 % of units reporting telemetry are on 4.2.2. Direct follow-up is under way with customers whose units have not updated.

Changes to prevent recurrence: the startup fail-closed check described above; a CI test asserting that every registered route carries an authorisation policy; extension of the pre-release test suite to cover unauthenticated access to all management endpoints.

Residual risk: units not yet updated and not applying the network restriction remain exploitable. Ongoing customer outreach is tracked internally as [internal reference].

Why this is good: the root cause is a specific, checkable engineering fact rather than a category (“human error”). The impact section states both what was found and the extent of the search that found it, which is what distinguishes “we looked and found nothing further” from “we did not look”. Attribution is explicitly marked unknown and the assessment is labelled as an assessment. Recurrence prevention is concrete and testable. Residual risk is stated rather than implied.

Pre-submission checklist

Run this before every submission, at every stage.

- ☐ Correct notification type selected — vulnerability or incident.
- ☐ Correct coordinating CSIRT selected, with the Article 14(7) basis recorded. Selecting the wrong one can invalidate the notification and require resubmission.
- ☐ Product name and version range match the technical documentation, not marketing naming.
- ☐ Member State list reflects distributor, importer and authorised-representative records, not just direct sales.
- ☐ Every timestamp is UTC and labelled as exact or estimated.
- ☐ Every factual claim has a source you could produce.
- ☐ Every conclusion is marked as a conclusion, with its basis.
- ☐ No speculation about actors, scope or root cause presented as fact.
- ☐ Unknowns stated as unknowns, not omitted.
- ☐ Sensitivity statement, where used, is specific about what is sensitive and why.
- ☐ The full submitted text is saved to the evidence log with its UTC submission time and the platform reference.
- ☐ The next deadline is computed, written down, and in a calendar with an alarm.
- ☐ Article 14(8) user-information duty considered and its status recorded — this is a separate obligation from notifying the CSIRT, and it is risk-based and proportionate: informing impacted users does not necessarily mean publishing details to the world.

Evidence and Decision Log

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

Why this log is the most important file in the pack

Article 14 hangs two consequences on a single moment in time: **when you became aware**. Every deadline is measured from it, and the maximum penalty tier — up to EUR 15 000 000 or 2.5 % of total worldwide annual turnover, whichever is higher (Article 64(2)) — attaches to failures under Article 14.

That moment is not self-evidencing. It is a judgement you make, in your own building, on partial information. The Commission's guidance of 27 July 2026, Section 9.1, defines it as the point at which, **after an initial assessment**, you have a **reasonable degree of certainty** that a vulnerability in your product is being actively exploited or that a severe incident has occurred and compromised your product's security. That formulation places the burden of demonstrating reasonableness on the party who made the assessment: you.

There are two distinct scenarios in which this log earns its keep.

You reported. A market surveillance authority, a customer, or a litigant asks why the early warning arrived on Friday when a security researcher had been discussing the issue publicly since Tuesday. The log shows: Tuesday's chatter was logged as a signal and assessed; the assessment could not connect the chatter to your build; Thursday's customer logs and your reproduction were what produced reasonable certainty; T0 was stamped Thursday 18:40 UTC; the early warning was filed 15 hours later. That is a reasoned, contemporaneous, timestamped chain. Without the log, you have a recollection.

You did not report. This is the harder case and the one the log exists for. You concluded that a KEV-listed CVE in a bundled library was not reachable in your product, and you filed nothing. Two years later, someone asks why. If the answer is a Slack thread that has aged out of retention and an engineer who has left the company, you have nothing. If the answer is a log entry naming the component and version you ship, the specific code path, the reason it is unreachable in your build, who verified it, how they verified it, and when — you have a defensible decision. **It is the artefact that defends a decision not to report.** A defensible decision that turns out to be wrong is a very different position from an undocumented decision that turns out to be wrong.

A third, quieter benefit: the log is what makes the 72-hour notification and the final report cheap to write. Everything those reports need was already captured, with timestamps, as it happened.

Rules for keeping it

1. **Contemporaneous.** Write entries as events happen, not in a reconstruction session afterwards. Reconstructed logs are worth materially less and are usually obvious as reconstructions.
2. **UTC, always.** Every timestamp in UTC, with the format `YYYY-MM-DD HH:MM`. Note whether each is exact or estimated.
3. **Append-only.** Never overwrite an entry. If an earlier entry was wrong, add a new entry correcting it and cross-reference both. A log with visible corrections is more credible than a log with none.
4. **Separate observation from conclusion.** "Customer reports outbound traffic from management interface" is an observation. "This is exploitation of the auth bypass" is a conclusion. Label which is which in the Basis

column.

5. **Name people.** Roles are not accountable; people are. Every decision entry carries a named decision-maker.
6. **Log the negatives.** “Checked internal telemetry for the exploitation pattern across the fleet; no matches” is an entry. Searches that found nothing are evidence that you searched.
7. **Attach the artefacts.** Reference the file, ticket, email, log excerpt or advisory by an identifier that will still resolve in five years. Store copies with the log; do not rely on a link to a third-party site or a chat message.
8. **Retain it.** Set a retention period that outlives any plausible enquiry. [VERIFY: your retention period with your own legal and records-management policy]
9. **One log per event.** A single event with both a vulnerability track and an incident track shares one log, with the track marked on each entry.
10. **Access control it, but do not make it hard to write.** A log nobody can add to at 03:00 will not be kept. A shared append-only document with named authors beats a formal system nobody can reach.

Entry types

Use a short type code in every row so the log can be read quickly under pressure.

Code	Meaning
SIG	Signal received. Something arrived. Not yet assessed.
ACT	Action taken — investigation step, search, test, contact.
OBS	Observation — a fact established, with its source.
DEC	Decision — including the awareness decision, and any decision not to report.
T0	The awareness stamp itself. There is exactly one per track.
FIL	A filing made, with platform reference and UTC submission time.
USR	User information activity under Article 14(8).
REV	Review or re-assessment of an earlier decision.

Log table template

Copy this into the incident record and append rows. Keep the columns; they are the questions someone will ask.

```
| # | UTC timestamp | Type | Track | Event / action | Source or evidence ref | Basis
(observation vs conclusion) | Person | Reportability position |
```

Column	What goes in it
#	Sequential, never reused.
UTC timestamp	YYYY-MM-DD HH:MM, marked (est.) if estimated.
Type	Code from the table above.
Track	VULN, INC, or BOTH.
Event / action	One or two factual sentences. What happened or what was done.
Source or evidence ref	Who or what it came from; the stored artefact identifier.
Basis	Whether this is observed fact or drawn conclusion, and on what.

Column	What goes in it
Person	Named individual.
Reportability position	The running answer: not assessed / assessing / not reportable – reason / REPORTABLE.

Filled example — Event EVT-2026-0141, actively exploited vulnerability

Product: GW-500 edge gateway, firmware 4.0–4.2.1. Made available in Belgium, Greece, Italy. Coordinating CSIRT: [VERIFY: your coordinating CSIRT].

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
1	2026-10-15 14:20	SIG	VULN	Email to product security inbox: customer SOC reports anomalous outbound traffic from the management interface of a GW-500 and suspects the appliance was the entry point. No logs attached.	EVT-0141/a01-customer-email.eml	Observation: message received. No technical evidence yet.	A. Reporter (accountable reporter)	not assessed
2	2026-10-15 14:28	ACT	VULN	Technical verifier paged. Investigation opened. Customer asked for management-interface logs and appliance serial/firmware version.	EVT-0141/a02-page-record.txt	Action.	A. Reporter	assessing
3	2026-10-15 14:55	ACT	VULN	Searched internal fleet telemetry for anomalous management-interface authentication patterns over the preceding 30 days. No matches found at this time.	EVT-0141/a03-telemetry-query.txt	Observation: negative search result. Absence of evidence in our telemetry, which covers only units that report telemetry.	B. Verifier (technical verifier)	assessing
4	2026-10-15 15:40	OBS	VULN	Customer confirms affected unit is on firmware 4.2.1, management interface reachable from a non-trusted	EVT-0141/a04-customer-call-notes.md	Observation, reported by customer, not independently verified at this point.	B. Verifier	assessing

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				network segment contrary to our deployment guidance.				
5	2026-10-15 17:10	OBS	VULN	Customer supplies management-interface logs. Logs show unauthenticated POST requests to <code>/api/v1/admin</code> accepted with HTTP 200, followed by creation of an administrative account not created by the customer's administrators, from external IP [redacted in this example].	EVT-0141/a05-customer-logs.tar.gz (SHA-256 recorded)	Observation from customer-supplied artefact.	B. Verifier	assessing — exploitation probable, not yet confirmed against our build
6	2026-10-15 18:12	ACT	VULN	Reproduced the request sequence against a stock 4.2.1 build in the lab. Unauthenticated request to <code>/api/v1/admin</code> accepted and executed with administrative privilege.	EVT-0141/a06-lab-repro.md, video a06-repro.mp4	Observation: reproduced in controlled environment.	B. Verifier	assessing
7	2026-10-15 18:35	OBS	VULN	Considered and excluded misconfiguration as an explanation: the customer's logs show the bypass on a default-configuration unit, and the lab reproduction used an unmodified stock build.	EVT-0141/a07-alt-explanations.md	Conclusion, from entries 5 and 6.	B. Verifier	assessing
8	2026-10-15 18:40	T0	VULN	AWARENESS DECLARED. Reasonable	entries 5, 6, 7	Decision. Awareness determination	A. Reporter	REPORTABLE — vulnerability track

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				degree of certainty that a vulnerability contained in the GW-500 is being actively exploited. Decisive facts: customer logs showing a successful unauthenticated privileged action and unauthorised account creation (entry 5), plus lab reproduction against a stock build (entry 6).		under Art. 14; standard applied: reasonable degree of certainty after initial assessment, per Commission guidance of 27 July 2026, Section 9.1.		
9	2026-10-15 18:44	DEC	VULN	Deadlines computed and posted: early warning due 2026-10-16 18:40 UTC; 72-hour notification due 2026-10-18 18:40 UTC; final report 14 days after a corrective or mitigating measure is available. Calendar alarms set at T0+12h and T0+20h.	EVT-0141/a09-deadlines.md	Action.	A. Reporter	REPORTABLE
10	2026-10-15 19:30	ACT	INC	Assessed whether our own build, signing or distribution systems were affected, i.e. whether a severe incident under Art. 14(5) also arises. Reviewed build system access logs and signing key usage for the preceding 60 days. No unauthorised access found.	EVT-0141/a10-build-review.md	Observation: negative search result over a defined scope and period.	C. Deputy (deputy reporter)	Incident track: not reportable — no evidence of impact on the security of our development, production or distribution processes

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
11	2026-10-16 08:00	ACT	VULN	Detection signature for the exploitation pattern distributed to the support organisation for customer log review.	EVT-0141/a11-signature.md	Action.	B. Verifier	REPORTABLE
12	2026-10-16 09:50	FIL	VULN	Early warning submitted via the single reporting platform. Coordinating CSIRT selected on the basis of main establishment in the Union. Member States indicated: Belgium, Greece, Italy. Full submitted text stored.	EVT-0141/a12-early-warning-submitted.md, platform ref [VERIFY: record the reference the platform returns]	Action. Filed 15h10m after T0, 8h50m before the deadline.	A. Reporter	REPORTABLE — stage 1 complete
13	2026-10-16 16:30	USR	VULN	Advisory published to customer portal and emailed to all registered GW-500 administrators: restrict management-interface access to trusted networks; review logs for the pattern; review administrative account list.	EVT-0141/a13-customer-advisory.pdf	Action under Art. 14(8).	D. Comms (communications lead)	REPORTABLE
14	2026-10-16 16:35	DEC	VULN	Noted that the published workaround may constitute a “mitigating measure available” starting the 14-day final-report clock. Two candidate trigger dates recorded: 2026-10-16 16:30	EVT-0141/a14-clock-basis.md	Decision, conservative interpretation.	A. Reporter	REPORTABLE

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				(workaround) and the future firmware release. Working deadline adopted on the earlier date, i.e. final report due 2026-10-30 16:30 UTC, to be revised only downwards.				
15	2026-10-17 11:20	OBS	VULN	Version bisection completes: the affected endpoint was introduced in 4.0; versions before 4.0 are unaffected. Affected range confirmed 4.0 to 4.2.1 inclusive.	EVT-0141/a15-version-bisect.md	Observation from code review and testing.	B. Verifier	REPORTABLE
16	2026-10-18 11:00	FIL	VULN	72-hour notification submitted , 7h40m before deadline. Includes confirmed version range, general nature of the exploit, published workaround, user actions, and a specific sensitivity statement. Full submitted text stored.	EVT-0141/a16-72h-submitted.md, platform ref [VERIFY]	Action.	A. Reporter	REPORTABLE — stage 2 complete
17	2026-10-22 09:15	OBS	VULN	Firmware 4.2.2 released and downloadable by all customers. Corrective measure available.	EVT-0141/a17-release-note.md	Observation.	B. Verifier	REPORTABLE
18	2026-11-03 10:05	FIL	VULN	Final report submitted , ahead of both the conservative deadline (2026-10-30, already met by an interim filing) and the release-anchored deadline (2026-	EVT-0141/a18-final-report.md, platform ref [VERIFY]	Action.	A. Reporter	REPORTABLE — closed

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				11-05 09:15). Includes root cause, severity, impact, actor information (attribution unknown, indicators supplied), corrective measure details, and recurrence prevention.				

Filled example — a decision NOT to report

This is the entry set that most organisations fail to keep, and the one that matters most. Event **EVT-2026-0158**.

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
1	2026-11-02 07:05	SIG	VULN	Automated dependency scan (crawatch) flags that our product bundles libexample 2.4.1, which carries CVE-2026-XXXXX, added to the CISA KEV catalog on 2026-11-01.	EVT-0158/b01-crawatch-report.json	Observation: a component we ship carries a CVE listed as known-exploited in the wild generally . This is a trigger to assess, not a finding about our product.	B. Verifier	assessing
2	2026-11-02 07:40	ACT	VULN	Read the upstream advisory and the KEV entry. Vulnerability is in libexample's optional XML-RPC request handler, exploitable only when the handler is registered and reachable over the network.	EVT-0158/b02-upstream-advisory.pdf , b03-kev-entry.json	Observation from vendor advisory.	B. Verifier	assessing

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
3	2026-11-02 08:55	ACT	VULN	Reachability analysis. Our build compiles libexample with --without-xmlrpc; the affected object file is absent from the shipped binary. Confirmed by symbol inspection of the release artefact for 3.7.0 (nm output stored) and by grep of the build configuration in the release pipeline definition.	EVT-0158/b04-symbol-inspection.txt, b05-build-config.md	Observation from direct inspection of the shipped artefact, not from documentation.	B. Verifier	assessing
4	2026-11-02 09:20	ACT	VULN	Searched product telemetry and support tickets for any indication of exploitation attempts against our product matching the advisory's indicators, covering 2026-08-01 to date. No matches.	EVT-0158/b06-telemetry-search.md	Observation: negative search result over a defined scope and period.	B. Verifier	assessing
5	2026-11-02 10:00	DEC	VULN	DECISION: NOT REPORTABLE under Article 14. The vulnerability originates in a third-party component we integrate. The vulnerable code is not reachable in our product because the affected handler	entries 2, 3, 4	Decision, with the legal basis and the factual basis both stated.	A. Reporter	not reportable — vulnerable code not reachable in our build; no exploitation observed in our product

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				is not compiled into our shipped binary (entry 3), and there is no evidence of exploitation in our product (entry 4). Per Commission guidance of 27 July 2026, Section 9.1, paragraph 218, a vulnerability in an integrated component that cannot be exploited in, or has not been exploited in, the manufacturer's product does not qualify as an actively exploited vulnerability contained in that product and is not subject to mandatory reporting. Decision made by the accountable reporter on the verifier's analysis.				
6	2026-11-02 10:15	ACT	VULN	Reported the vulnerability upstream to the libexample maintainers under Article 13(6). Checked first that the maintainers were already aware — advisory is theirs — so the report was limited to confirming the version we	EVT-0158/b07-upstream-report.eml	Action under Art. 13(6).	B. Verifier	not reportable

#	UTC timestamp	Type	Track	Event / action	Source or evidence ref	Basis	Person	Reportability position
				integrate and offering test results.				
7	2026-11-02 10:30	DEC	VULN	Scheduled upgrade of <code>libexample</code> to 2.4.3 in the next maintenance release (target 2026-11-24) notwithstanding non-reachability, to eliminate the exposure if build options ever change. Tracked as <code>[internal ticket ref]</code> .	<code>EVT-0158/b08-remediation-ticket.md</code>	Decision, risk reduction beyond the legal minimum.	B. Verifier	not reportable
8	2026-11-02 10:35	DEC	VULN	Considered voluntary notification under Article 15 and decided against it on the basis that the upstream advisory is already public and adds nothing for the CSIRT in this instance. Recorded so the decision is visible.	<code>EVT-0158/b09-art15-consideration.md</code>	Decision.	A. Reporter	not reportable
9	2026-11-24 14:00	REV	VULN	Re-assessment on release of 3.7.1: confirmed <code>--without-xmllrpc</code> remains set and <code>libexample</code> upgraded to 2.4.3. Non-reachability conclusion re-verified against the new artefact.	<code>EVT-0158/b10-reverify.txt</code>	Observation. Conclusion re-verified, not assumed to persist.	B. Verifier	not reportable — re-verified

Read entry 5 again. It names the legal test, applies it to two specific facts, cites the evidence for each fact, and names the decision-maker. Entry 9 shows the conclusion was re-checked rather than treated as permanent. That combination is what makes a non-report defensible.

Common failures this log prevents

Failure	What it looks like later	The entry that prevents it
Awareness drift	Nobody can say when the clock started; the earliest email in the thread becomes the assumed T0 by default.	A single T0 entry naming the decisive facts.
Reconstruction	The log is written after the final report, in one sitting, from memory.	Contemporaneous entries with tight timestamps.
Undocumented non-report	“We looked at it and decided it didn’t apply.”	A DEC entry with the legal test, the facts, and the evidence refs.
Missing negatives	“Did you check whether other customers were affected?” “Yes, I think so.”	ACT entries recording searches that found nothing, with their scope and period.
Silent re-scoping	The affected version range in the final report differs from the early warning with no explanation.	An OBS entry recording the bisection result and when it landed.
Clock-basis ambiguity	Two plausible dates for “measure available”; the later one was used.	A DEC entry recording both candidates and the choice of the earlier.
Vanished artefacts	The customer log tarball is on a laptop that was reimaged.	Stored copies with hashes, referenced by stable identifiers.

Roles and Dry Run

This pack is engineering and process tooling, not legal advice. Verify against Regulation (EU) 2024/2847 and guidance from your coordinating national CSIRT before filing.

The staffing principle

Article 14 compresses a regulatory filing into 24 hours. The organisations that fail it rarely lack technical capability; they lack **availability and authority** at the moment the clock starts. Two failure patterns account for most misses:

- **No single owner.** Everybody assumed somebody was watching the deadline. The technical investigation absorbed all attention and the filing was nobody's specific job.
- **Authority sitting above availability.** The only person authorised to submit was unreachable, and nobody else believed they were allowed to press the button.

So the model here is deliberately small and deliberately explicit: **one accountable reporter, one deputy with identical authority, one technical verifier, one communications lead**. Four named humans. Not four teams, not four job titles.

Roles in the first 24 hours

1. Accountable reporter (single, named)

Owns: the decision that awareness has occurred, the T0 stamp, every deadline, and every submission.

- Declares awareness and stamps T0 in UTC in the evidence log. This is a decision, not a consensus.
- Computes the three deadlines and posts them, in UTC, where everyone working the event can see them.
- Drafts and submits the early warning, the 72-hour notification and the final report.
- Decides which coordinating CSIRT applies under Article 14(7) and records the basis.
- Owns the evidence log's integrity — entries get made, nothing gets overwritten.
- Has **standing authority to file without further approval**. Write this down and have it signed by whoever needs to sign it, once, in advance. An approval chain that requires an executive who is on a flight is a defect, not a control.

Must have, in advance: a personal EU Login account with MFA enabled; registration on the reporting platform as Primary Assigned Representative; a tested login within the last quarter; the coordinating CSIRT determination already made and written down; the product inventory with Member State availability.

Does not do: the technical investigation. The reporter who disappears into a debugger stops watching the clock.

2. Deputy reporter (single, named)

Owns: everything the accountable reporter owns, whenever the accountable reporter is unreachable.

- Identical authority. Not “can escalate to” — can file.
- Registered on the platform as a Secondary Assigned Representative, with their own EU Login and MFA, tested.

- Takes the file on a defined handover, with a verbal statement of T0 and the three deadlines, echoed back.
- Covers the rota so that at no hour is there zero people with filing authority. Handover happens at a stated UTC time, recorded in the log.

The deputy is not a backup in the sense of “we’ll find someone”. Deputy is a duty with a name on it and a tested platform login.

3. Technical verifier (single, named, may rotate)

Owens: the factual answers the decision tree needs.

- Runs gates 1 to 5 of `01-DECISION-TREE.md`: product identification, version range, exploitation evidence, third-party component reachability, severe-incident test.
- Performs and records the reachability analysis when a third-party component is involved — the most contestable judgement in the process.
- Runs the negative searches (fleet telemetry, support tickets, build-system logs) and records their scope and period, not just their result.
- States findings as observations, and states conclusions as conclusions with their basis.
- Tells the reporter the moment a mitigating or corrective measure becomes available to users, with the UTC timestamp, because that starts the 14-day final-report clock.

Explicitly not owned by the verifier: the awareness decision. The verifier supplies facts and a technical opinion; the reporter makes the call and carries it.

4. Communications lead (single, named)

Owens: Article 14(8) — informing impacted users, and where appropriate all users — plus all outward messaging.

- Prepares user-facing advisories: what is affected, what users should do, in what order.
- Applies the risk-based, proportionate standard from the Commission’s guidance of 27 July 2026, Section 9.1: informing users does not automatically mean publishing full technical detail to the world, particularly where the product is used in sensitive environments and public detail could increase risk. Broader disclosure becomes appropriate once the issue is adequately addressed or mitigated.
- Keeps the customer-facing message consistent with what was filed. Divergence between a public statement and a regulatory notification is a self-inflicted problem.
- Handles press, customer escalations and account-team traffic so the reporter and verifier are not interrupted.
- **Never** holds up the early warning to align a press cycle. The notification to the CSIRT is confidential and is not a public disclosure; Article 16(2) exists for genuine coordination needs.

Supporting, not on the critical path

- **Legal counsel** — advises on interpretation and on interaction with other regimes (NIS2, DORA, GDPR — the same event may trigger separate duties on separate clocks). Advises; does not gate the filing.
- **Executive sponsor** — informed, resources the response, does not approve individual filings.
- **Records owner** — ensures evidence artefacts are stored with hashes and survive laptop reimaging and staff departures.

The first 24 hours, by the clock

Window	Accountable reporter	Technical verifier	Comms lead
T-minus (signal received)	Open the evidence log. Record the signal verbatim with UTC timestamp and source. Do not declare awareness.	Begin the initial assessment immediately. Promptness here is itself part of the legal standard.	Standby. Hold all outward statements.
Assessment	Run the decision tree with the verifier. Record an answer and a reason at every gate.	Answer gates 1–5. Reproduce, verify, search, record negatives.	Prepare a holding position for inbound customer questions.
T0	Declare awareness. Stamp T0 in UTC. Say it aloud on the call. Post the three deadlines.	Continue investigation; feed facts to the reporter as they land.	Begin drafting the user advisory.
T0 + 0–4h	Draft the early warning from the template. Confirm the coordinating CSIRT and the Member State list.	Confirm affected version range as far as possible. Assess whether a severe-incident track also arises.	Circulate the advisory draft for technical accuracy.
T0 + 4–12h	Submit the early warning as soon as it is accurate. Do not wait for the deadline.	Root-cause work; scope of affected fleet.	Publish user guidance once a workaround exists. Record UTC time.
T0 + 12–24h	Confirm submission recorded in the log with platform reference. Set alarms for the 72-hour deadline. Brief the deputy; hand over if needed.	Continue. Report the exact UTC time any mitigating measure becomes available to users.	Track customer questions; feed recurring ones into the 72-hour notification’s user-actions field.

30-minute tabletop dry run

Run this twice a year, and after every change of accountable reporter. Thirty minutes, four people, one facilitator, no laptops except the one holding the evidence log. The facilitator holds the injects and does not participate.

Objective: prove that awareness can be declared, deadlines computed, and an early warning drafted, by the people who will actually have to do it, without looking anything up that should already be written down.

Setup (2 minutes)

Facilitator states: “This is an exercise. Nothing filed today is real. We are testing the process, not the people. All times are UTC and today is a Friday — the exercise clock starts at 16:10 UTC.” Confirm the four roles are present and who is playing each.

Inject 1 — the signal (minute 2)

16:10 UTC. An email arrives at the product security inbox from a customer’s security operations centre: “We had an intrusion. Our forensics people think the entry point was your appliance. We’re still working on it — will send logs when we can. Someone should probably look at this.”

Separately, a support engineer mentions in a channel that a security researcher posted on a public forum two days ago about “auth weirdness” in your product line. Nobody followed it up.

Questions to the team (5 minutes):

1. Has the clock started? (Correct answer: **no**. This is a signal. It starts the duty to assess promptly, not the 24 hours.)
2. What goes in the evidence log right now, and who writes it?
3. Who is paged, and how — by name and by what mechanism? Does that mechanism work at 16:10 on a Friday?
4. What is asked of the customer, and by whom?
5. What is done about the two-day-old forum post? (Log it as a signal; assess it; note that it was not connected to anything at the time.)

Failure to watch for: the team starts debugging and nobody opens the log.

Inject 2 — evidence firms up (minute 7)

18:05 UTC. The customer sends management-interface logs. They show unauthenticated requests to an administrative endpoint being accepted, followed by creation of an administrative account the customer says they did not create. Your engineer reproduces the same behaviour against a stock build of the current release in the lab at 18:40.

The affected code path came from a third-party library you bundle.

Questions to the team (8 minutes):

1. Is this now awareness? If yes, what exactly is T0 and who declares it? (Expected: **yes**, T0 = 18:40 UTC, declared by the accountable reporter — reasonable certainty after initial assessment.)
2. The flaw came from a third-party component. Does that change anything? (Expected: you must still assess reachability — but here it **is** reachable and **has been** exploited in your product, so you report. The component's own manufacturer may also owe a report; that does not discharge yours.)
3. Compute the deadlines out loud, in UTC. (Early warning: Saturday 18:40. 72-hour notification: Monday 18:40. Final report: 14 days after a corrective or mitigating measure is available — not yet computable.)
4. Who is working Saturday? Name them.
5. Does the accountable reporter have platform access **right now**? Have them state their EU Login status from memory. If the answer involves "I'd have to check", that is a finding.

Failure to watch for: the team waits for root cause before declaring awareness. Reasonable certainty is not certainty.

Inject 3 — the complication (minute 15)

21:30 UTC. The accountable reporter's phone goes to voicemail; they are on a long-haul flight and unreachable for nine hours. Separately, a journalist emails the press address asking about "a breach at one of your customers".

Engineering reports they will not have a fix or a workaround before Monday.

Questions to the team (8 minutes):

1. Who files the early warning? Does the deputy have platform access and standing authority, in writing? (If anyone says "we'd wait for them to land" — that is the finding of the day.)
2. Exactly how does the handover happen, and what is written in the log?
3. What does the comms lead say to the journalist? What does the comms lead **not** say?
4. Does the absence of a fix delay the early warning? (No. The early warning is deliberately thin. File with what you have and state the unknowns.)

5. Draft the early warning summary field out loud, in three sentences. Facilitator judges it against the standard in 03-REPORT-TEMPLATES.md: factual, neutral, dated, unknowns stated.

Failure to watch for: any suggestion of holding the notification to coordinate a public statement.

Debrief (minute 23 to 30)

Score four things. Write each finding with an owner and a due date, and put them in the same tracker as engineering work.

#	Check	Pass criterion
1	Awareness	The team distinguished signal from awareness, and declared T0 at the right moment with a stated basis.
2	Authority	Someone could have filed at every hour of the scenario, with tested platform access.
3	Arithmetic	All three deadlines computed correctly in UTC, out loud, without a calculator argument.
4	Artefact	The evidence log contains contemporaneous entries a stranger could follow.

Common findings, in rough order of frequency: only one person has platform access; nobody can state the coordinating CSIRT from memory or find it in under a minute; the Member State availability list does not exist; the deputy’s authority is assumed rather than written; the log was not opened until after T0.

One-page wall chart

Print this. Put it where the on-call engineer can see it. Fill in the bracketed fields before you need them.

```
+=====+
|          CRA ARTICLE 14 - FIRST 24 HOURS - WALL CHART          |
|  Not legal advice. Verify against Regulation (EU) 2024/2847 and your  |
|  coordinating national CSIRT's guidance before filing.             |
+=====+
|  WHO                                                             |
|  Accountable reporter : [name] ..... [phone] .....           |
|  Deputy reporter      : [name] ..... [phone] .....           |
|  Technical verifier   : [name] ..... [phone] .....           |
|  Comms lead           : [name] ..... [phone] .....           |
|  Both reporters have EU Login + MFA and platform access. Tested: [date] |
|                                                                    |
|  WHERE REPORTS GO                                                |
|  Single reporting platform (ENISA, Art. 16)                      |
|  Coordinating CSIRT  : [VERIFY: your CSIRT designated as coordinator] |
|  Basis (Art. 14(7))  : [main establishment / AR / importer / dist / users]|
|  Member States where our products are made available:          |
|  [.....]                                                       |
|                                                                    |
+-----+
| STEP 1  SIGNAL              Log it. UTC timestamp + source.      |
```

	THIS IS NOT AWARENESS. Assess it NOW.
STEP 2 ASSESS	Run 01-DECISION-TREE.md. Six gates: 1 product with digital elements? 2 made available on the EU market? 3 reliable evidence of real-world exploitation? (NOT CVSS. NOT a PoC.) 4 third-party component - reachable AND exploited IN OUR product? 5 or: severe incident, Art. 14(5)? 6 reasonable certainty after assessment?
STEP 3 DECLARE	Reasonable degree of certainty = AWARENESS. STAMP T0 IN UTC. SAY IT ALOUD. LOG IT.
STEP 4 CLOCKS	T0 + 24h -> EARLY WARNING T0 + 72h -> FULLER NOTIFICATION Vulnerability: FINAL REPORT 14 DAYS after a corrective or mitigating measure is AVAILABLE Severe incident: FINAL REPORT 1 MONTH after the 72-hour notification is SUBMITTED No weekend or holiday extension. Ever.
STEP 5 FILE	At 24h, file even if you know little. The early warning is MEANT to be thin. State unknowns as unknowns. Never guess.
STEP 6 USERS	Art. 14(8): inform impacted users, and where appropriate all users. Risk-based and proportionate - not automatically public.
STEP 7 RECORD	Evidence log: every signal, action, decision. If you decide NOT to report, WRITE WHY.
+-----+	
NEVER	
	- Wait for root cause before declaring awareness - Wait for a fix before filing the early warning - Hold the notification to align a press statement - Treat a high CVSS or a public PoC as proof of exploitation - Assume a KEV listing means it is exploited IN OUR product - Leave a "not reportable" decision undocumented
SCOPE REMINDERS	
	- Products already on the EU market before 11 Dec 2027 ARE in scope for Article 14 (Art. 69(3)). - Reporting duties continue after the support period ends. - Penalties for Art. 14 failures: up to EUR 15 000 000 or 2.5 % of total worldwide annual turnover, whichever is higher (Art. 64(2)).
+=====+	

Pre-incident readiness checklist

Everything below must be true **before** an incident. Each item that is false is a deadline you will miss.

- ☐ Accountable reporter and deputy named in writing, with standing authority to file without further approval.

- ☐ Both hold personal EU Login accounts with MFA enabled, and are registered on the reporting platform (one Primary Assigned Representative, at least one Secondary).
- ☐ A login has been tested within the last 90 days. Record the date.
- ☐ Coordinating CSIRT determined under Article 14(7), with the basis written down, and contact details recorded. [VERIFY: against ENISA's published list of CSIRTs designated as coordinators and your national CSIRT's website]
- ☐ Product inventory maintained: every product with digital elements made available on the EU market, including products placed on the market before 11 December 2027 and products past end of support.
- ☐ Member State availability list maintained from importer, distributor and authorised-representative records.
- ☐ A staffed intake channel exists that a customer, researcher or agency can reach, and someone actually watches it outside business hours.
- ☐ On-call rota covers every hour, with named substitutes, and at every hour at least one person holds filing authority.
- ☐ Evidence log location known to all four roles and writable from a phone.
- ☐ Wall chart printed and posted; bracketed fields filled in.
- ☐ Tabletop run within the last six months, with findings closed.
- ☐ Dependency scanning in place so that a KEV-listed CVE in a shipped component surfaces as a trigger to assess, not as a surprise. cra-watch produces exactly this input.